

Control	Control Title	Applicable?
A.5.1	Policies for information security	Yes
A.5.2	Information security roles and responsibilities	Yes
A.5.9	Inventory of information and other associated assets	Yes
A.5.12	Classification of information	Yes
A.5.15	Access control	Yes
A.5.16	Identity management	Yes
A.5.17	Authentication information	Yes
A.5.18	Access rights	Yes
A.5.19	Information security in supplier relationships	Yes
A.5.20	Addressing information security within supplier agreements	Yes
A.5.22	Monitoring, review and change management of supplier services	Yes
A.5.23	Information security for use of cloud services	Yes
A.5.24	Information security incident management planning and preparation	Yes
A.5.26	Response to information security incidents	Yes
A.5.30	ICT readiness for business continuity	Yes
A.5.31	Legal, statutory, regulatory and contractual requirements	Yes
A.5.34	Privacy and protection of PII	Yes
A.6.3	Information security awareness, education and training	Yes
A.6.8	Information security event reporting	Yes
A.8.5	Secure authentication	Yes
A.8.8	Management of technical vulnerabilities	Yes
A.8.15	Logging	Yes
A.8.16	Monitoring activities	Yes
A.8.20	Network security	Yes
A.8.24	Use of cryptography	Yes

A.8.25	Secure development life cycle	Yes
A.8.28	Secure coding	Yes
A.8.29	Security testing in development and acceptance	Yes
A.8.32	Change management	Yes

Justification	Implementation Status
Addresses incomplete security policies and provides management direction.	Partially Implemented
Clarifies accountability for security decisions, risks and controls.	To Be Assessed / Implemented
Directly addresses the absence of a formal asset inventory.	Not Implemented
Supports proportionate handling of customer, transaction, employee and financial information.	To Be Assessed / Implemented
Defines business and security rules for access to information and systems.	To Be Assessed / Implemented
Supports identity lifecycle from creation through change and removal.	To Be Assessed / Implemented
Protects passwords, secrets and other authentication information.	To Be Assessed / Implemented
Supports provisioning, review, modification and removal of access rights.	To Be Assessed / Implemented
Addresses supplier security governance and risk requirements.	Partially Implemented
Places security responsibilities and obligations into supplier contracts.	Partially Implemented
Requires ongoing review of supplier security and service changes.	Partially Implemented
Relevant because NovaPay uses cloud-based systems.	To Be Assessed / Implemented
Creates defined incident roles, procedures and readiness.	To Be Assessed / Implemented
Supports consistent containment, eradication, recovery and communication.	To Be Assessed / Implemented
Supports resilience and recovery of payment services and supporting technology.	To Be Assessed / Implemented
Requires NovaPay to identify, document and maintain applicable Irish, EU and contractual obligations for its services and markets.	To Be Assessed / Implemented
Relevant because NovaPay processes customer and employee personal information in an Ireland/EU operating context.	To Be Assessed / Implemented
Directly addresses irregular security awareness training.	Partially Implemented
Helps personnel promptly report suspicious events and incidents.	To Be Assessed / Implemented
Reduces credential-based compromise risk.	To Be Assessed / Implemented
Provides a formal process for identifying and treating exploitable weaknesses.	To Be Assessed / Implemented
Provides evidence for detection, investigation and accountability.	To Be Assessed / Implemented
Supports timely detection of anomalous or malicious activity.	To Be Assessed / Implemented
Protects networked services and communications supporting the payment environment.	To Be Assessed / Implemented
Supports confidentiality and integrity of sensitive information in storage and transfer where required.	To Be Assessed / Implemented

Embeds security throughout development and change activities.	To Be Assessed / Implemented
Reduces the likelihood of application vulnerabilities introduced in code.	To Be Assessed / Implemented
Requires security testing before systems or significant changes are accepted.	To Be Assessed / Implemented
Reduces uncontrolled or unauthorized changes to production-supporting systems.	To Be Assessed / Implemented

Case Evidence / Note	Gap Link
Policies exist but are incomplete.	G02
Case evidence does not confirm formal role assignment.	G09
Case explicitly states no formal asset inventory.	G03
Classification process evidence is not provided.	G03
Access-control effectiveness evidence is not provided.	G02,G09
Identity lifecycle evidence is not provided.	G09
Authentication-information handling evidence is not provided.	G09
Periodic access-review evidence is not provided.	G09
Third-party checks exist but are inconsistent.	G08
Supplier checks exist; contract-security evidence is not provided.	G08
Third-party checks are inconsistent.	G08
Cloud governance evidence is not provided.	G08
Formal tested incident planning evidence is not provided.	G09
Incident-response effectiveness evidence is not provided.	G09
Continuity testing evidence is not provided.	G09
Detailed Irish/EU obligations register is not provided; GDPR applicability should be confirmed and evidenced for personal-data processing.	G10
Privacy-control evidence is not provided; GDPR-aligned privacy controls should be validated where applicable.	G10
Training exists but is irregular.	G07
Formal event-reporting evidence is not provided.	G07,G09
Authentication-control effectiveness evidence is not provided.	G09
Vulnerability-management evidence is not provided.	G10
Logging coverage evidence is not provided.	G10
Monitoring effectiveness evidence is not provided.	G10
Network-security control evidence is not provided.	G10
Cryptographic-control evidence is not provided.	G10

Secure SDLC evidence is not provided.	G10
Secure-coding evidence is not provided.	G10
Security-testing evidence is not provided.	G10
Formal change-control evidence is not provided.	G10

Risk Link

R01-R12

R01,R03,R09-R11

R04

R01,R04,R11

R01,R12

R01,R02,R12

R01,R02

R01,R12

R03,R10

R03,R10,R11

R03,R10

R03,R06,R10

R09

R09

R10

R11

R01,R11

R02

R02,R09

R01,R02

R05-R07

R01,R08,R12

R01,R08,R09

R06,R10

R01,R03,R11

R05

R05

R05

R05,R06